

Social Engineering and Phishing Cheat Sheet

12 tables · 72 concepts · Updated 2026-04-30 · [cheatgrid.com](#)

Social engineering is a **psychological manipulation technique** used by attackers to exploit human behavior rather than technical vulnerabilities—targeting trust, curiosity, fear, or urgency to deceive victims into revealing sensitive information or performing unauthorized actions. **Phishing** represents the most prevalent form, using fraudulent communications (email, SMS, voice, QR codes) to impersonate legitimate entities. Understanding this threat landscape is critical because **no technical defense is complete without addressing the human element**—employees remain the primary attack vector in most data breaches. The key insight: social engineering attacks succeed not by breaking code, but by **manipulating the decision-making process** under psychological pressure, making awareness and verification protocols your strongest defense.

CONTENTS

Email-Based Phishing Attack Types1

Multi-Channel Phishing Techniques2

Social Engineering Manipulation Tactics2

Physical Social Engineering Methods3

Phishing Indicators and Red Flags3

Defense-in-Depth Technical Controls4

Security Awareness Training Components5

Key Performance Indicators and Metrics5

Psychological Manipulation Principles6

Verification Protocols and Countermeasures6

Incident Response and Reporting Workflow7

Advanced and Emerging Threats7

References8

TABLE 1
Email-Based Phishing Attack Types

Phishing isn't one thing—it scales from blasting millions of inboxes to handcrafting a single message for one executive. These types sort that spectrum: spear phishing and whaling target named individuals with researched detail, BEC and clone phishing weaponize trust in familiar senders, and pharming skips the user's judgment entirely by poisoning DNS. The more tailored the attack, the higher its success rate.

Type	Example	Description
Spear Phishing	Email to CFO: "Hi Sarah, urgent wire transfer needed for Project Phoenix—see attached invoice" with researched project details	• Highly targeted attack against specific individuals using personalized information gathered through reconnaissance • significantly higher success rate than mass phishing
Whaling	Fake legal subpoena sent to CEO's personal email requesting immediate document disclosure	• Executive-level spear phishing targeting C-suite and senior management • exploits authority and access to financial systems • also called CEO fraud when impersonating executives
Clone Phishing	Resending legitimate invoice email from supplier with payment details changed to attacker's account	• Duplicates previously sent legitimate message with malicious modifications • exploits familiarity and trust in recognizable communications
Business Email Compromise (BEC)	"From CEO: Wire \$250K to new vendor account immediately—confidential acquisition, don't discuss with finance"	• Sophisticated impersonation of executives or vendors to authorize fraudulent wire transfers or payroll redirects • \$50 billion in losses globally (FBI 2023).

Type	Example	Description
Angler Phishing	Fake customer support account on Twitter responds to complaint: "DM us your account details to resolve"	Social media attacks where attackers create fake customer service accounts to intercept complaints and harvest credentials from frustrated users.
Watering Hole Attack	Compromising industry association website frequently visited by defense contractors to deliver malware	• Infecting websites commonly visited by specific target groups rather than attacking targets directly • exploits trusted browsing habits
Pharming	DNS cache poisoning redirects users typing "bank.com" to attacker's identical-looking site at different IP	• DNS manipulation that redirects legitimate website traffic to malicious sites without user interaction • bypasses URL inspection by users

TABLE 2

Multi-Channel Phishing Techniques

Attackers go wherever email filters can't follow—your phone, your texts, a QR code on a poster, or a real-time proxy of a login page. Vishing and smishing exploit the trust we place in calls and SMS, quishing hides the payload in an image, and adversary-in-the-middle and deepfake attacks are specifically built to defeat MFA and a familiar voice. Each channel sidesteps a control that email security would have caught.

Technique	Example	Description
Vishing (Voice Phishing)	Call claiming to be from "Microsoft Security" warning of computer infection, requesting remote access	• Phone-based attacks using voice calls or voicemail to impersonate trusted organizations • surged 442% in 2024 with AI voice cloning capabilities
Smishing (SMS Phishing)	Text: "Your package delivery failed. Reschedule: http://bit.ly/pkg-track [malicious link]"	• Text message scams delivering phishing links via SMS • bypasses email security controls and exploits mobile device trust
Quishing (QR Code Phishing)	Email with QR code: "Scan for multi-factor authentication update" leading to credential harvesting page	• QR code-embedded attacks that bypass text-based email filters • users scan codes on mobile devices outside corporate security perimeter
Adversary-in-the-Middle (AiTM)	Phishing site proxies real login page in real-time, capturing credentials AND session tokens to bypass MFA	• Real-time interception of authentication between user and legitimate service • defeats multi-factor authentication by stealing active session cookies
Deepfake Phishing	AI-cloned CEO voice calls CFO: "I'm in a confidential meeting—wire \$240K now, details via email shortly"	• AI-generated audio or video impersonating executives or trusted individuals • requires only 5 minutes of source audio for convincing voice clones

TABLE 3

Social Engineering Manipulation Tactics

Beyond the delivery channel sits the con itself—the story an attacker tells to make you comply. Pretexting invents a believable scenario, baiting and quid pro quo dangle a reward or a favor, and tailgating simply exploits the human reflex to hold a door open. Each tactic targets a different lever: curiosity, helpfulness, fear, or plain politeness.

Tactic	Example	Description
Pretexting	Caller impersonates IT support: "We're updating systems, I need your employee ID and password to migrate your account"	• Creating fabricated scenario (pretext) to establish false trust and extract information • often involves impersonating authority figures or service providers
Baiting	USB drives labeled "Employee Salary 2026 Confidential" left in company parking lot	• Enticement with promised reward—physical media, free downloads, or exclusive content—that delivers malware when accessed • exploits curiosity

Tactic	Example	Description
Quid Pro Quo	"Hi, this is tech support returning your call about printer issues—let me remote in to fix it" (unsolicited)	• Offering service or benefit in exchange for information or access • differs from baiting by promising assistance rather than goods
Tailgating (Piggybacking)	Following employee through secure door while carrying boxes: "Could you hold the door? My badge is in my pocket"	• Physical security breach where unauthorized person follows authorized individual into restricted area • exploits politeness and social norms
Scareware	Pop-up: "CRITICAL: 47 viruses detected! Download SecurityDefender Pro NOW or lose all data!"	• Fake security alerts presenting false threats to frighten users into installing malware or purchasing worthless software • also called rogue antivirus
Honey Trap (Romance Scam)	Attacker builds online relationship over weeks, eventually requesting money or access to corporate VPN "to help with project"	• Romantic or sexual relationship manipulation to gain trust and extract money, information, or network access • often combined with espionage
Diversion Theft	Email to delivery driver: "Change of plans—deliver server equipment to warehouse on Oak St instead of headquarters"	• Redirect legitimate transactions to attacker-controlled location • applies to physical deliveries, wire transfers, or data transmissions

TABLE 4

Physical Social Engineering Methods

Not every attack arrives over a wire—some happen in the parking lot, at the badge reader, or over your shoulder. Dumpster diving and shoulder surfing harvest information the cheap way, while badge cloning and impersonation get an attacker bodily inside a building. These are a reminder that the strongest firewall does nothing against a confident stranger in a vendor uniform.

Method	Example	Description
Dumpster Diving	Searching company trash bins for printed documents containing passwords, org charts, or project names	• Physical searching of discarded materials for sensitive information • surprisingly effective as many organizations fail to shred documents properly
Shoulder Surfing	Observing employee entering badge code while standing behind them at secure entrance	Visual surveillance to capture passwords, PINs, or sensitive data by watching target's screen or keyboard from nearby location.
Badge Cloning	Using RFID reader disguised as badge holder to capture and duplicate employee access credentials	• Duplicating RFID access cards by wirelessly capturing credential data • enables unauthorized physical access to facilities
Impersonation	Attacker wears fake vendor uniform with company logo and claims to need access for "scheduled maintenance"	• Posing as legitimate personnel—contractor, delivery, IT support—to gain physical access or information • relies on social authority

TABLE 5

Phishing Indicators and Red Flags

The tells that give a phishing message away once you know to look. Generic greetings and manufactured urgency reveal mass distribution and psychological pressure, while a mismatched sender domain or a hovered-over lookalike URL exposes the deception outright. No single flag is proof, but two or three together should stop you cold—especially the cardinal rule that legitimate organizations never ask for your password by email.

Indicator	Example	Description
Generic Greetings	"Dear Valued Customer" or "Hello User" instead of your actual name	• Lack of personalization suggests mass distribution • legitimate organizations typically use your name in communications
Urgent or Threatening Language	"IMMEDIATE ACTION REQUIRED: Account suspension in 24 hours" or "Unusual activity detected—verify NOW"	• Psychological pressure designed to bypass rational thinking • creates artificial time constraints to prevent verification

Indicator	Example	Description
Suspicious Sender Address	Display name "Apple Support" but email address "apple-security@outlook-verify.com"	• Mismatched or lookalike domains • always check actual email address, not just display name—display name spoofing is trivial
Poor Grammar and Spelling	"Your account have been compromise. Click here for restore access immediately."	• Language errors indicating non-professional source • though AI-generated phishing has significantly improved quality in 2024-2026.
Unexpected Attachments	Invoice.pdf.exe or compressed files with macros from unknown sender	• Malicious payloads disguised as documents • common formats include .exe, .scr, .zip, .html, .svg files designed to bypass filters
URL Manipulation	Hovering reveals actual URL: "http://microsfot.com-login.tk" or "http://192.168.1.1/paypal"	• Obfuscated or lookalike links • techniques include homograph attacks (using similar Unicode characters), IP addresses instead of domains, URL shorteners
Requests for Sensitive Information	"Verify your account by replying with username, password, and social security number"	• Legitimate organizations never request credentials via email • red flag for any request for passwords, SSN, or financial details

TABLE 6

Defense-in-Depth Technical Controls

No single control stops phishing, so these stack into layers that each catch what the previous one missed. Email authentication verifies the sender, gateways and sandboxing filter and detonate suspicious content, URL rewriting protects against links that turn malicious after delivery, and phishing-resistant MFA plus Zero Trust limit the damage when something inevitably slips through. The phish-reporting button closes the loop by turning every employee into a sensor.

Control	Example	Description
Email Authentication (SPF, DKIM, DMARC)	v=DMARC1; p=reject; rua=mailto:dmarc@company.com in DNS records	• Cryptographic verification of sender identity • SPF checks authorized IPs, DKIM validates message integrity, DMARC enforces policy and provides reporting
Email Security Gateway (SEG)	Barracuda, Proofpoint, or Mimecast analyzing all inbound messages before delivery	• Cloud or on-premise filtering for spam, malware, phishing links, and malicious attachments • uses reputation databases and heuristics
Sandboxing	Suspicious .pdf attachment automatically detonated in isolated virtual machine to observe behavior	• Dynamic analysis in controlled environment • executes unknown files to detect malicious behavior before reaching user inbox
URL Rewriting and Analysis	Email links automatically proxied through security service that inspects destination in real-time	• Time-of-click protection against URLs that become malicious after email delivery • checks destination reputation before allowing access
Multi-Factor Authentication (MFA)	FIDO2 hardware keys, biometric authentication, or time-based authenticator apps	• Second authentication factor beyond passwords • note that SMS and TOTP codes vulnerable to AiTM attacks—phishing-resistant MFA (hardware keys) recommended
Zero Trust Architecture	Microsegmentation, continuous verification, least-privilege access policies enforced at network layer	• Never trust, always verify model • assumes breach and limits lateral movement through granular access controls and continuous authentication
Phish Reporting Button	One-click "Report Phishing" button integrated into Outlook/Gmail that automatically alerts security team	• Streamlined user reporting mechanism • enables rapid incident response and provides valuable threat intelligence from user community

TABLE 7
Security Awareness Training Components

Since people are the target, training the people is the control—but only if it actually changes behavior. Realistic phishing simulations and short interactive modules beat annual compliance videos, gamification and security champions drive the engagement that makes lessons stick, and customized content keeps scenarios relevant to the threats your industry really faces.

Component	Example	Description
Phishing Simulation	Monthly simulated phishing emails with varying difficulty; tracks click rate, reporting rate, credential entry	• Realistic testing that measures susceptibility and trains recognition skills • should escalate difficulty and avoid punitive approaches—focus on learning
Interactive Training Modules	Scenario-based micro-learning: "You receive this email—what do you do?" with immediate feedback	• Engaging educational content delivered in short, focused segments • dramatically more effective than annual compliance training videos
Gamification	Points, badges, leaderboards for reporting suspicious emails; competitions between departments	• Game mechanics to drive engagement and behavior change • proven to increase participation rates 100-150% over traditional training
Security Champions Program	Designating security-passionate employees in each department as go-to resources and advocates	• Peer influence network that embeds security culture • champions receive advanced training and promote best practices within teams
Customized Content	Industry-specific scenarios: healthcare (HIPAA phishing), finance (wire fraud), manufacturing (supply chain attacks)	• Relevant, contextualized training that reflects actual threats faced by organization • significantly improves retention and application

TABLE 8
Key Performance Indicators and Metrics

These metrics tell you whether your awareness program is moving the needle or just checking a box. Click rate is the obvious one, but reporting rate and time-to-report matter more—they measure employees who actively defend rather than merely avoid mistakes. Repeat-offender rate, meanwhile, pinpoints the small cohort that drives most of your human risk.

Metric	Example	Description
Phishing Click Rate	Initial baseline 32% clicking malicious links → 8% after 12 months of training program	• Percentage clicking phishing simulations • downward trend indicates improving awareness • industry average 10-30% for untrained users
Reporting Rate	Users reporting 67% of phishing simulations within 5 minutes of receipt	• Proactive threat detection by users • more important than click rate—employees actively defending rather than passively avoiding mistakes
Time to Report	Average reporting speed decreased from 4 hours to 12 minutes after training improvements	• Speed of threat detection and escalation • faster reporting enables quicker incident response and limits potential damage
Repeat Offender Rate	3% of users account for 40% of all simulation failures; targeted remediation reduces this cohort	• Persistent high-risk individuals • identifies users requiring additional support or role-based restrictions to mitigate organizational risk
Training Completion Rate	98% of employees completed mandatory annual training and quarterly refreshers on schedule	• Program participation • foundation metric—cannot improve behavior without engagement • track completion quality, not just quantity

TABLE 9

Psychological Manipulation Principles

These are the cognitive buttons every social engineering attack presses, drawn largely from Cialdini's principles of influence. Authority, urgency, and fear short-circuit careful thinking, while reciprocity, social proof, and liking exploit our instinct to trust and reciprocate. Spotting which lever a message is pulling is often faster than analyzing the technical details—and it's what awareness training ultimately aims to make automatic.

Principle	Example	Description
Authority	Email appearing from CEO or law enforcement demanding immediate compliance	• Obedience to perceived power • humans follow instructions from authority figures without questioning—attackers impersonate executives, IT, legal
Urgency (Scarcity)	"Offer expires in 1 hour" or "Account will be deleted in 24 hours if you don't act now"	• Time pressure that prevents rational evaluation • creates artificial deadline to bypass normal verification procedures and security training
Fear	"Your computer is infected" or "Suspicious login detected from Russia—verify immediately to prevent account lockout"	• Threat-based manipulation • exploits anxiety about security, financial loss, or legal consequences to trigger impulsive action
Reciprocity	Free gift, helpful tip, or unsolicited favor offered before making request for sensitive information	• Social obligation to repay favors • humans feel compelled to return gestures of goodwill—attackers establish debt before exploitation
Social Proof	"Join 50,000 satisfied customers" or fake social media profiles showing colleagues using malicious service	• Following the crowd • humans trust actions validated by others—attackers fabricate popularity, endorsements, or testimonials
Liking (Familiarity)	Attacker researches target's interests via social media, builds rapport through shared hobbies before requesting access	• Trust from perceived similarity • humans more likely to help people they like or identify with—attackers mirror interests and values

TABLE 10

Verification Protocols and Countermeasures

The procedures that defeat manipulation by refusing to take a request at face value. Out-of-band and callback verification break the attack chain by confirming through a separate, trusted channel, while least privilege and dual authorization make sure that even a successful con can't move large amounts of money or data alone. Built into the workflow, these turn a moment of doubt into a hard stop.

Protocol	Example	Description
Out-of-Band Verification	Email requests wire transfer → always call using phone number from company directory (not email) to confirm	• Verify using different communication channel than the request • breaks attack chain by forcing attacker to compromise multiple systems
Callback Verification	Unknown caller requests password reset → hang up, call IT help desk using known number to validate request	• Proactive confirmation through independently obtained contact information • defeats vishing and impersonation by verifying identity before action
Least Privilege Access	Finance staff can only access accounts payable system, cannot approve wire transfers exceeding \$10K individually	• Minimum necessary permissions to perform job functions • limits damage from compromised accounts by restricting scope of actions
Dual Authorization	Wire transfers above \$5K require approval from two different managers using separate authentication	• Multi-person approval for high-risk transactions • introduces friction that makes social engineering attacks significantly more difficult
Information Classification	Clear labeling of confidential data and policies restricting sharing on social media or public channels	• Control disclosure of sensitive information • reduces reconnaissance opportunities for attackers gathering data for targeted attacks

Protocol	Example	Description
Physical Access Controls	Mantraps, security badges with photos, escort requirements for visitors, anti-tailgating awareness	• Prevent unauthorized physical entry • layered controls including ID verification, badge readers, security personnel, and employee vigilance

TABLE 11

Incident Response and Reporting Workflow

What happens after someone reports a suspicious email—the assembly line that turns a single report into protection for everyone. A low-friction reporting button feeds automated triage and threat-intelligence enrichment, containment yanks the message from every mailbox, and post-incident analysis feeds the lessons back into detection and training. Speed at each step is what limits the blast radius.

Step	Example	Description
User Reporting Mechanism	Phish button in email client forwards suspicious message to security-phishing@company.com automatically	• Low-friction reporting path • should require single click—making it easier to report than delete increases participation dramatically
Automated Triage	SOAR platform analyzes reported emails using threat intelligence, URL scanning, header analysis; categorizes severity	• Rapid initial assessment using automation • filters false positives, prioritizes genuine threats, and routes to appropriate response tier
Threat Intelligence Enrichment	Reported URL checked against VirusTotal, PhishTank, internal blocklists; sender domain analyzed for SPF/DKIM/DMARC	• Contextual investigation using multiple sources • determines if threat is part of targeted campaign or widespread attack
Containment Actions	Delete malicious email from all mailboxes, block sender domain at gateway, revoke session tokens if credentials entered	• Rapid mitigation to limit exposure • automated remediation can remove threats from thousands of mailboxes within minutes
User Communication	Notify affected users, provide clear instructions for password reset if credentials compromised, explain what happened	• Transparent incident handling that reinforces learning • using incidents as teachable moments improves future resilience
Post-Incident Analysis	Document attack tactics, update detection rules, incorporate new patterns into training simulations, share IOCs	• Continuous improvement from real incidents • feeds lessons learned back into prevention and detection capabilities

TABLE 12

Advanced and Emerging Threats

Where phishing is heading as attackers industrialize and adapt. Credential-harvesting pages and ready-made phishing kits lower the skill bar to near zero, OAuth device-code abuse and AiTM steal access without ever stealing a password, and supply-chain phishing hits you through a trusted vendor you'd never think to doubt. These are the techniques outpacing yesterday's filters—and the reason defense has to keep evolving.

Threat	Example	Description
Credential Harvesting Pages	Fake Microsoft 365 login page captures username/password and immediately tests credentials on real system	• Phishing landing pages designed to steal login credentials • often include fake CAPTCHA or MFA prompts to appear legitimate
Phishing Kits	Pre-built Social Engineer Toolkit (SET) with templates for major brands, automated credential capture, SMS forwarding	• Packaged attack tools lowering barrier to entry • Phishing-as-a-Service (PhaaS) platforms enable non-technical criminals to launch campaigns
SEO Poisoning	Fake customer support pages ranking #1 in Google for "Adobe help phone number" directing to vishing scammers	Search engine manipulation where attackers optimize malicious content to appear in top results for support-related queries.
Typosquatting	Registering "gooogle.com" or "micros0ft.com" to capture traffic from typing mistakes	• Lookalike domain registration exploiting common typos • includes combosquatting (brand + common word) and homograph attacks (Unicode lookalikes).

Threat	Example	Description
OAuth Device Code Phishing	QR code leads to OAuth flow: "Sign in on your device"—user authenticates, attacker receives access token	• Abuse of legitimate OAuth flows to obtain authorization tokens without stealing passwords • bypasses traditional phishing detection
Supply Chain Phishing	Compromising trusted vendor email to send malware from legitimate account to all customers	Third-party compromise where attackers infiltrate suppliers, partners to attack target from trusted source—extremely difficult to detect.
Insider Threat (Socially Engineered)	External attacker manipulates employee through romance scam or financial coercion to provide VPN access	• Compromising legitimate insiders through social engineering to gain persistent access • blurs line between external and internal threats

References

Official Documentation and Standards

1. FBI Internet Crime Complaint Center - Business Email Compromise - <https://www.fbi.gov/how-we-can-help-you/scams-and-safety/common-frauds-and-scams/business-email-compromise>
2. CISA Zero Trust Microsegmentation Guidance - <https://www.cisa.gov/news-events/alerts/2025/07/29/cisa-releases-part-one-zero-trust-microsegmentation-guidance>
3. NIST Technical Note 2276: NIST Phish Scale User Guide - <https://csrc.nist.gov/pubs/tn/2276/final>
4. NIST SP 800-207: Zero Trust Architecture - <https://pages.nist.gov/zero-trust-architecture/>
5. Microsoft Email Threat Landscape Q1 2026 - <https://www.microsoft.com/en-us/security/blog/2026/04/30/email-threat-landscape-q1-2026-trends-and-insights/>

Technical Blogs and Analysis

6. CrowdStrike - Types of Social Engineering Attacks - <https://www.crowdstrike.com/en-us/cybersecurity-101/social-engineering/types-of-social-engineering-attacks/>
7. Fortinet - Tailgating Attack Definition and Prevention - <https://www.fortinet.com/resources/cyberglossary/tailgating-attack>
8. Cloudflare - What is Domain Spoofing? - <https://www.cloudflare.com/learning/ssl/what-is-domain-spoofing/>
9. Proofpoint - Fraudulent Social Media Accounts and Angler Phishing - <https://www.proofpoint.com/us/threat-insight/post/fraudulent-social-media-accounts-continue-phish-banking-credentials>
10. Valimail - Complete Guide to Business Email Compromise (BEC) - <https://www.valimail.com/blog/essential-guide-to-bec-attacks/>
11. Norton - 20 Types of Phishing Attacks - <https://us.norton.com/blog/online-scams/types-of-phishing>
12. IBM - What is Smishing (SMS Phishing)? - <https://www.ibm.com/think/topics/smishing>
13. Check Point Software - What is Quishing (QR Phishing)? - <https://www.checkpoint.com/cyber-hub/threat-prevention/what-is-phishing/what-is-quishing-qr-phishing/>
14. Obsidian Security - Session Hijacking and Token Theft - <https://www.obsidiansecurity.com/blog/session-hijacking-how-it-works-how-to-stop-it>
15. Vectra AI - Deepfake Phishing and AI-Powered Attacks - <https://www.vectra.ai/topics/ai-phishing>
16. Hive Security - AitM Phishing: How Attackers Bypass MFA - <https://hivesecurity.gitlab.io/blog/aitm-phishing-mfa-bypass-evilinx/>
17. Keepnet Labs - What is Deepfake Phishing? - <https://keepnetlabs.com/blog/what-is-deepfake-phishing>
18. Huntress - Credential Harvesting Phishing Guide - <https://www.huntress.com/phishing-guide/credential-harvesting-phishing>
19. Hoxhunt - 14 Phishing Red Flags Your Users Need to Know - <https://hoxhunt.com/blog/phishing-red-flags>
20. Keeper Security - Common Indicators of a Phishing Attempt - <https://www.keepersecurity.com/blog/2023/08/09/what-are-common-indicators-of-a-phishing-attempt/>

Security Awareness Training

21. KnowBe4 - Security Awareness Training Platform - <https://www.knowbe4.com/products/security-awareness-training>
22. Security Mentor - Phishing Awareness Training - <https://www.securitymentor.com/>
23. PhishLabs/PhishTitan - Phishing Simulation Tools - <https://phriendlyphishing.com/>
24. Wizer Training - Security Awareness Champions Program - <https://www.wizer-training.com/blog/forging-allies-for-security-awareness-champions-program>
25. Keepnet Labs - Gamification in Security Awareness - <https://keepnetlabs.com/blog/gamification-security-awareness-training>
26. Hoxhunt - Does Gamified Cyber Security Training Work? - <https://hoxhunt.com/blog/gamified-cyber-security-training>
27. Inspired eLearning - Gamification in Security Awareness - <https://inspiredelearning.com/blog/gamification-in-security-awareness-training/>
28. Infosecurity Magazine - Security Champions Programs - <https://www.infosecurity-magazine.com/news-features/security-champions-cultural/>
29. Cybersecurity News - Building Security Champions Program - <https://cybersecuritynews.com/security-champions-program/>
30. Adaptive Security - Building Security Awareness Culture - <https://www.adaptivesecurity.com/blog/building-a-lasting-security-awareness-culture-that-reduces-human-risk>

Metrics and Measurement

31. PhishSheriff - Phishing Simulation KPIs and Metrics - <https://www.phishsheriff.com/post/phishing-simulation-kpis-training-effectiveness>
33. Adaptive Security - Phishing Metrics That Matter - <https://www.adaptivesecurity.com/blog/measure-phishing-simulation-program>
35. Cyber Learning Hub - Measuring Phishing Awareness KPIs - <https://cyberlearninghub.com/blog/phishing-awareness-metrics>
37. Proofpoint - Measuring Security Awareness Training - <https://www.proofpoint.com/us/blog/security-awareness-training/measuring-metrics-benchmarks-and-communicating-security-awareness>
32. Living Security - Phishing Resilience Metrics 2026 - <https://www.livingsecurity.com/blog/phishing-simulation-risk-metrics>
34. CIRA - How to Measure Phishing Test Programs - <https://www.cira.ca/en/resources/news/cybersecurity/phishing-test-metrics-measurement/>
36. Hoxhunt - 4 Essential Phishing Metrics - <https://hoxhunt.com/blog/4-essential-phishing-metrics>
38. Mimecast - How to Measure Human Risk: 7 Key Metrics - <https://www.mimecast.com/blog/how-to-measure-human-risk-7-key-metrics/>

Email Security and Authentication

39. DMARCLY - How to Implement DMARC/DKIM/SPF - <https://dmarcly.com/blog/how-to-implement-dmarc-dkim-spf-to-stop-email-spoofing-phishing-the-definitive-guide>
41. Mailjet - Email Authentication Protocols Explained - <https://www.mailjet.com/blog/deliverability/email-authentication/>
43. SpamTitan - Email Sandboxing Explained - <https://www.spamtitan.com/email-sandboxing/>
45. GreatHorn - Prevent & Detect Malicious Payloads - <https://www.greathorn.com/solutions/attack-types/malicious-payloads/>
40. yourDMARC - Email Authentication with SPF, DKIM, DMARC - <https://www.yourdmarc.com/>
42. PhishProtection.com - Stop Phishing Emails with DMARC - <https://www.phishprotection.com/phishing/stop-phishing-emails-fast-dmarc-spf-and-dkim-made-simple>
44. GlockApps - Email Sandboxing Protection - <https://glockapps.com/blog/email-sandboxing-explained-how-it-protects-your-inbox-from-malware-and-phishing/>

Phishing Techniques and Tactics

46. Check Point Research - Cyber Criminals Using URL Tricks - <https://blog.checkpoint.com/cyber-criminals-using-url-tricks-to-deceive-users/>
48. NordVPN - What is Link Manipulation? - <https://nordvpn.com/blog/link-manipulation/>
50. Allure Security - Brand Impersonation Overview - <https://alluresecurity.com/blog/brand-impersonation-overview/>
52. Paubox - Display Name Spoofing - <https://www.paubox.com/blog/display-name-spoofing>
54. McAfee - How to Spot Fake Antivirus Software - <https://www.mcafee.com/learn/fake-antivirus-software/>
47. Push Security - URL Obfuscation Techniques - <https://phishing-techniques.pushsecurity.com/techniques/url-obfuscation/>
49. Cloudflare - What is Brand Impersonation? - <https://www.cloudflare.com/learning/ssl/what-is-domain-spoofing/>
51. Carnegie Mellon - Email Spoofing Identification - <https://www.cmu.edu/iso/news/2020/email-spoofing.html>
53. ExpressVPN - What is Fake Antivirus Software? - <https://www.expressvpn.com/blog/what-is-fake-antivirus/>
55. Social Catfish - Social Engineering Attacks Guide - <https://socialcatfish.com/scamfish/social-engineering-attacks-2/>

Social Engineering Psychology

56. Ransom Leak - Social Engineering Cialdini Principles - <https://ransomleak.com/threats/social-engineering/>
58. CryptoSafetyFirst - Fear and Urgency Tactics - <https://cryptosafetyfirst.com/fear-urgency-psychological-pressure-tactics/>
60. LinkedIn - Psychology Behind Phishing Attacks (AMATAS) - <https://amatas.com/blog/the-psychology-behind-phishing-attacks-and-how-to-train-against-it/>
62. ScienceDirect - Psychological Manipulation of Phishing - <https://www.sciencedirect.com/org/science/article/pii/S1546221825009968>
57. Ninjio - Urgency in Social Engineering - <https://ninjio.com/blog/blog-urgency-social-engineering-phishing-attacks/>
59. Cyberly - How Phishing Uses Urgent Language - <https://www.cyberly.org/en/how-do-phishing-attacks-use-urgent-language-to-trick-victims/index.html>
61. Don't Click That Link: Psychology Behind Phishing - <https://massdata.com/psychology-behind-phishing-attacks/>

Physical Security

63. Avigilon - Tailgating and Piggybacking Attacks - <https://www.avigilon.com/blog/tailgating-and-piggybacking>
65. Bluefire Redteam - RFID Cloning Explained - <https://bluefire-redteam.com/rfid-cloning-explained/>
67. ZDNET - \$10 Device to Clone RFID Access Keys - <https://www.zdnet.com/article/getting-physical-a-10-device-to-clone-rfid-access-keys-on-the-go/>
69. Getkisi - How to Copy RFID Access Cards - <https://www.getkisi.com/blog/how-to-copy-access-cards-and-keyfobs>
64. TechTarget - What is Tailgating (Piggybacking)? - <https://www.techtarget.com/whatis/definition/tailgating-piggybacking/>
66. Shadecoder - Badge Cloning Guide 2025 - <https://www.shadecoder.com/topics/badge-cloning-a-comprehensive-guide-for-2025>
68. RFID Label - RFID Cloning: How Hackers Use It - <https://www.rfidlabel.com/rfid-cloning-how-hackers-use-it-and-what-you-can-do-to-safeguard-our-data/>

Defense and Prevention

70. Startup Defense - Social Engineering Countermeasures - <https://www.startupdefense.io/blog/social-engineering-why-your-startup-is-the-easiest-target>
71. Valydex - BEC Verification Guide - <https://valydex.com/guides/spot-the-fake-bec-verification-guide>

- 72. NordLayer - Principle of Least Privilege - <https://nordlayer.com/learn/access-control/principle-of-least-privilege/>
- 73. Zvelo - Social Engineering Countermeasures - <https://zvelo.com/social-engineering-countermeasures/>
- 74. BimStudies - Social Engineering Countermeasures - <https://bimstudies.com/docs/it-ethics-and-cybersecurity/social-engineering-and-cyber-terrorism/social-engineering-countermeasures/>
- 75. Complete AI Training - Defending Against AI Social Engineering - <https://completeaitraining.com/news/from-deepfakes-to-help-desk-scams-detect-and-defend-against/>

Incident Response

- 76. Material Security - Phishing Incident Response Automation - <https://material.security/resources/phishing-incident-response-automate-your-abuse-mail-box-and-cut-triage-and-response-time>
- 77. Swimlane - How to Address Phishing Triage - <https://swimlane.com/solutions/use-cases/phishing/>
- 78. Keepnet Labs - Secure Human Behavior and Reporting - <https://keepnetlabs.com/blog/secure-human-behavior-recognizing-and-reporting-phishing-emails>
- 79. Medium - Improving Incident Response with LLMs (Agoda) - <https://medium.com/agoda-engineering/improving-security-incident-response-at-agoda-with-large-language-models-78b1f33151e0>
- 80. D3 Security - What is SOAR? - <https://d3security.com/soar-security-orchestration-automation-and-response/>
- 81. Swimlane - SOAR Playbooks Guide - <https://swimlane.com/blog/soar-playbooks/>
- 82. Hoxhunt - Top Phishing Attack Factors - <https://hoxhunt.com/blog/top-3-phishing-attack-factors-time-desktop-mobile>

Advanced Threats

- 83. Obsidian Security - AiTM Attacks Overview - <https://www.obsidiansecurity.com/blog/what-are-man-in-the-middle-mitm-attacks>
- 84. Swissbit - Bypassing MFA with AiTM Attacks - <https://www.swissbit.com/en/blog/post/bypassing-mfa-the-rise-of-adversary-in-the-middle-aitm-attacks/>
- 85. StoneFly - How AiTM Phishing Threatens Enterprise - <https://stonefly.com/blog/how-aitm-phishing-threatens-enterprise-security/>
- 86. Darktrace - MFA Under Attack: AiTM Phishing Kits - <https://www.darktrace.com/blog/mfa-under-attack-aitm-phishing-kits-abusing-legitimate-services>
- 87. Datadog Security Labs - Adversary-in-the-Middle Phishing - <https://securitylabs.datadoghq.com/cloud-security-atlas/attacks/adversary-in-the-middle-phishing/>
- 88. Reality Defender - Deepfake Whaling Defense - <https://www.realitydefender.com/insights/deepfake-whaling-defense>
- 89. Breacher.ai - Synthetic Identity Phishing - <https://breacher.ai/blog/synthetic-identity-phishing/>
- 90. Neurealm - Deepfake Phishing Using AI - <https://www.neurealm.com/blogs/deepfake-phishing-using-ai/>
- 91. Adaptive Security - Deepfake Phishing Evolution - <https://www.adaptivesecurity.com/blog/deepfake-phishing>
- 92. Rasec - Deepfake Phishing 2.0 - <https://rasec.app/blog/deepfake-phishing-2-0-ai-emotional-manipulation-2026>
- 93. LinkedIn - AI-Powered Phishing and Deepfakes - <https://www.linkedin.com/pulse/ai-powered-phishing-deepfakes-social-engineering-growing-yadav-lb-a8c>

QR Code and Mobile Threats

- 94. QR.io - Quishing Alert: How to Spot QR Code Scams - <https://qr.io/blog/quishing-alert-how-to-spot-and-thwart-qr-code-phishing-scams/>
- 95. Uniqode - Secure QR Codes Against Quishing - <https://www.uniqode.com/blog/qr-code-security/secure-qr-codes-against-phishing-and-quishing-attacks>
- 96. Hoxhunt - QR Code Phishing (Quishing) Explained - <https://hoxhunt.com/blog/quishing>
- 97. Malwarebytes - Quishing: QR Phishing Explained - <https://www.malwarebytes.com/cybersecurity/basics/quishing>
- 98. Acronis - Why QR Code Phishing is 2026 Blind Spot - <https://www.acronis.com/en/blog/posts/qr-code-phishing-evasive-threats-2026/>
- 99. IBM - What is Smishing? - <https://www.ibm.com/think/topics/smishing>
- 100. Kaspersky - What is Smishing and How to Defend - <https://www.kaspersky.com/resource-center/threats/what-is-smishing-and-how-to-defend-against-it>
- 101. Identity Guard - What is Smishing? - <https://www.identityguard.com/news/smishing-meaning>
- 102. Zscaler - What is Smishing (SMS Phishing)? - <https://www.zscaler.com/zpedia/what-is-smishing-sms-phishing>

Business Email Compromise

- 103. Microsoft Security - What is BEC? - <https://www.microsoft.com/en-us/security/business/security-101/what-is-business-email-compromise-bec>
- 104. Norton - Business Email Compromise Explained - <https://us.norton.com/blog/account-safety/business-email-compromise>
- 105. LinkedIn - BEC and CEO Fraud Explained - <https://www.linkedin.com/pulse/business-email-compromise-ceo-fraud-explained-laone-moalosi-ob1df>
- 106. KnowBe4 - CEO Fraud Attacks - <https://www.knowbe4.com/ceo-fraud>
- 107. Prophet Security - Investigating BEC: Practical Approach - <https://www.prophetsecurity.ai/blog/investigating-business-email-compromise-bec-a-practical-approach>

Tools and Platforms

- 108. TrustedSec - Social Engineer Toolkit (SET) - <https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set>
- 109. GitHub - Phishing Kit Topics - <https://github.com/topics/phishing-kit>
- 110. StationX - How to Use Social Engineer Toolkit - <https://www.stationx.net/social-engineer-toolkit/>
- 111. CheckPhish - Free Phishing Link Checker - <https://checkphish.bolster.ai/>
- 112. CanIphish - Phishing Email Detection Tools - <https://caniphish.com/blog/types-of-phishing-payloads>
- 113. Push Security - Detecting Phishing Using Obfuscated URLs - <https://pushsecurity.com/blog/detecting-phishing-pages-using-obfuscated-url-destinations/>

Insider Threats

- 114. Cyberproof - Insider Threats, AI and Social Engineering - <https://www.cyberproof.com/blog/insider-threats-ai-and-social-engineering-the-triad-of-modern-cybersecurity-threats/>
- 115. Social Engineer - Insider Threats: Hidden Danger - <https://www.social-engineer.com/insider-threats-unveiling-the-hidden-danger/>
- 116. Forbes - Rise of Socially Engineered Insider - <https://www.forbes.com/councils/forbestechcouncil/2024/05/03/the-rise-and-stealth-of-the-socially-engineered-insider/>
- 117. Cyberly - Social Engineering and Insider Threats - <https://www.cyberly.org/en/how-does-social-engineering-relate-to-insider-threats/index.html>
- 118. HutSix - Malicious Insider Threats - <https://www.hutsix.io/malicious-insider-threats/>

OSINT and Reconnaissance

- 119. OSINT Framework - <https://osintframework.com/>
- 120. Unite.ai - Best Open Source Intelligence Tools - <https://www.unite.ai/best-open-source-intelligence-osint-tools/>
- 121. UserSearch - Top 10 OSINT Tools on GitHub - <https://usersearch.org/updates/top-10-rated-osint-tools-from-github>
- 122. LinkedIn - Oversharing and OSINT - <https://www.linkedin.com/pulse/oversharing-open-source-intelligence-osint-pavan-teja-somisetty-4ikdc>
- 123. Infosec Academy - OSINT Framework and Tools - <https://www.infosecinstitute.com/osint-framework/>

Supply Chain and Third-Party Risks

- 124. TeamWin - Axios NPM Compromise via Social Engineering - <https://teamwin.in/axios-maintainer-confirms-the-npm-compromise-was-via-a-targeted-social-engineering-attack/>
- 125. LinkedIn - Supply Chain Attacks Overview - <https://www.linkedin.com/pulse/from-phishing-to-supply-chain-attacks-inside-look-at-recent-kaled-o4apc>

Zero Trust and Architecture

- 126. Venn - Zero Trust Architecture in 2026 - <https://www.venn.com/learn/zero-trust/zero-trust-architecture/>
- 127. Cloudflare - What is Microsegmentation? - <https://www.cloudflare.com/learning/access-management/what-is-microsegmentation/>
- 128. Palo Alto Networks - What is Microsegmentation? - <https://www.paloaltonetworks.com/cyberpedia/what-is-microsegmentation>
- 129. Tata Communications - Zero Trust Microsegmentation - <https://www.tatacommunications.com/knowledge-base/ztna/zero-trust-microsegmentation>
- 130. Zero Networks - Microsegmentation and Zero Trust - <https://zeronetworks.com/blog/microsegmentation-and-zero-trust>
- 131. Microsoft Learn - Secure Networks with Zero Trust - <https://learn.microsoft.com/en-us/security/zero-trust/deploy/networks>

Industry Reports and Statistics

- 132. Phishing Statistics and Trends 2026 (VikingCloud) - <https://www.vikingcloud.com/blog/phishing-statistics>
- 133. Barracuda - PhishLine Data Sheet - [https://static1.squarespace.com/static/51141873e4b07596654edd16/t/5b747664562fa7f9a52109d1/1534359140884/Barracuda_PhishLine_Data_Sheet_\(American_English\).pdf](https://static1.squarespace.com/static/51141873e4b07596654edd16/t/5b747664562fa7f9a52109d1/1534359140884/Barracuda_PhishLine_Data_Sheet_(American_English).pdf)
- 134. ACFE Fraud Magazine - Scareware Fraud - <https://www.acfe.com/fraud-magazine/all-issues/issue/article?s=2011-marapr-scareware-fraud-part-one>
- 135. ODNI - Common Sense Guide to Insider Threats - <https://www.odni.gov/files/NCSC/documents/nittf/20180209-CERT-Common-Sense-Guide-Fifth-Edition.pdf>

Educational Resources

- 136. ITU Online - Understanding Social Engineering - <https://www.ituonline.com/blogs/understanding-social-engineering/>
- 137. Space Bound Solutions - 5 Types of Social Engineering - <https://blog.spaceboundssolutions.com/home/2022/4/12/5-types-of-social-engineering-a-ttacks-and-how-to-combat-them>

- 138.** LinkedIn - Understanding Social Engineering Impact - <https://www.linkedin.com/pulse/understanding-impact-social-engineering-cyberattacks-jatin-to-pakar-fz27c>
- 140.** Clayton State University - Information Security: Phishing - <https://www.clayton.edu/its/it-security/cyber/phishing.php>
- 142.** Cisco - What is Vishing? - <https://www.cisco.com/site/us/en/learn/topics/security/what-is-vishing.html>
- 144.** Imperva - What is Quishing? - <https://www.imperva.com/learn/application-security/quishing/>
- 139.** Serverman - Social Engineering: The Human Hack - <https://www.serverman.co.uk/cyber-security/social-engineering-the-human-hack-how-cybercriminals-manipulate-people-into-giving-away-data/>
- 141.** University of Michigan - Phone Scams and Vishing - <https://safecomputing.umich.edu/protect-yourself/phishing-scams/common-scams/phone-scams>
- 143.** TrendMicro - What is Tailgating? - https://www.trendmicro.com/en_us/what-is/social-engineering/what-is-tailgating.html
- 145.** Vectra - Account Takeover (ATO) Prevention - <https://www.vectra.ai/topics/account-takeover>

Case Studies and Examples

- 146.** Forcepoint - Fake DHL Phishing Campaign - <https://www.forcepoint.com/blog/x-labs/fake-dhl-phishing-campaign-credential-theft>
- 147.** Malwarebytes - Job Scam Using Fake Google Forms - <https://www.malwarebytes.com/blog/scams/2026/02/job-scam-uses-fake-google-forms-site-to-harvest-google-logins>
- 148.** KnowBe4 - 245% Increase in SVG Files for Phishing - <https://blog.knowbe4.com/245-increase-in-svg-files-used-to-obfuscate-phishing-payloads>
- 149.** Cybersecurity News - Examples of Phishing Attacks - <https://cybersecuritynews.com/examples-of-phishing-attacks/>
- 150.** Marketing Scoop - CEO/CFO Phishing Scams Guide - <https://www.marketingscoop.com/tech/dont-let-your-business-become-another-statistic-an-expert-guide-to-thwarting-cfo-ceo-phishing-scams/>